

AisleSignals Implementation and Build Plan

Functional Requirements Technical Design and Delivery Roadmap

Prepared by Jawahir Q. | 13 September 2026 | Implementation baseline 2.2

1 Executive Summary and Build Baseline

AisleSignals is an approved pharmacy-only project. This plan defines the software, integration work, operational controls and acceptance evidence needed to deliver a working service for two Irish community-pharmacy pilot sites. It is a build specification and delivery baseline, not a claim that the application, detector or installations already exist.

The initial product receives supported camera observations, alerts a named staff reviewer, supports a safe response, preserves evidence and records the final outcome. Staff can also create incidents and assistance requests manually. Small AI jobs draft factual reports and summarise reviewed records. Specialist theft detection is purchased or evaluated through an authorised supplier integration; the core application remains independent of that supplier.

The baseline assumes two separate customer organisations, one site each, one or two initially qualified camera views per site on the existing laptop, expanded only after measurement, Codex as implementation lead, bounded specialist agents for implementation and independent review, and Jawahir Q. as product owner. Site ownership, existing laptop OS versions, processor architectures and capacity, detector API rights, processing terms, actual fees and staff availability must be recorded during discovery. These unknowns do not prevent building the application against synthetic fixtures and a simulator.

Build through six acceptance-based work packages, followed by site commissioning and an eight-week operational pilot. There is no hired engineering team and no retained twelve-week engineering promise. Calendar estimates will follow measured agent throughput on the first complete workflow and the actual supplier/site lead times. Agent work advances when this task is running; it does not constitute unattended hosting, support or physical installation. External delays remain dependencies, and simulated detection is never presented as an accepted live product.

The deliverables are a pharmacy web application, API and worker services, a companion application installed on the existing pharmacy laptop, a supported detector adapter, a private evidence service, deployment configuration, acceptance tests and operating runbooks. The handover pack includes machine-readable requirements, a revised OpenAPI contract, data model, backlog, test catalogue and commissioning records. Production credentials, customer footage and supplier-specific undocumented protocols are not included. The user-provided repository is [g784dwcd2r-crypto/AisleSignals](https://github.com/g784dwcd2r-crypto/AisleSignals), and pushes are authorised. The confirmed commercial baseline is EUR 60 monthly for one pharmacy branch. A company with multiple branches needs a separately agreed subscription for each activated branch. No new hardware is to be purchased. Tax treatment, software onboarding and specialist detection terms must be resolved before selling a live configuration.

2 Release Scope and Delivery Gates

MVP means the first supported operational release. OPTION means a supported software connection to an already installed attention-sounder system; it never includes new relays or equipment. P2 means work after the core pilot succeeds. Each feature is enabled by site and capability, rather than activated globally because a deployment completed.

Release	Included	Exit condition
MVP application	Identity, organisation/site permissions, shifts, incidents, evidence, private alerts, assistance, bounded AI drafts, reporting, retention and support tools	Functional, isolation, evidence, recovery and operator tests pass
MVP live integration	Qualified existing camera views, laptop companion and supported software interface, contracted event and media access, health and model provenance	Each site and enabled detection class passes commissioning and evaluation
OPTION	Staff-authorized existing attention sounder through a supported software API, with fresh context and signed expiring commands	Separate physical-output acceptance; failure does not block a scoped software-only release
P2	Approved stock imports, discrepancy tasks, procedure retrieval, recall/expiry coordination and aggregate forecasting	Confirmed demand, data rights, reliable identifiers and a separately estimated extension backlog

Automatic cross-visit recognition, facial templates, shared offender watchlists, person-level criminality scoring, autonomous clinical decisions, automatic public alarms from AI and door-lock control remain outside the build. Earlier-case links are restricted human annotations with reasons and retention review. They do not create automatic recognition.

Gate	Required evidence	Accountable decision
G0 Build kickoff	Scope, named product owner, team capacity, repository ownership and discovery appointments	Jawahir Q. or nominated project owner
G1 Integration route	Exact incoming event fields, outgoing event rights, media access/export rights, existing laptop compatibility and software licence terms	Technical lead and commercial owner
G2 Site readiness	Camera/network inventory, reviewer coverage, processing records, local credentials and agreed response procedure	Pharmacy manager, existing IT contact and privacy owner
G3 Application readiness	Contract tests, role/site isolation, evidence lifecycle, retention, cost caps and recovery evidence	Technical lead and QA lead
G4 Detection readiness	Site-specific held-out evaluation, known limitations, alert workload and threshold/version record	Pharmacy manager and technical lead
G5 Live pilot	Training, support contacts, rollback controls, baseline measurements and critical tests passed	Product owner and each pharmacy manager

Gate	Required evidence	Accountable decision
G6 Wider rollout	Measured value, acceptable staff burden, actual delivery cost, retention and support capacity	Commercial owner and project sponsor

If G1 fails, continue building and testing the workflow with the simulator. A supplier app plus manual incident entry can validate the workflow, but it is a separate operating route and does not establish integrated-product feasibility. Partner or reseller status alone is insufficient evidence of event and media rights. ¹

3 Agent Delivery Model and Milestones

Codex is the implementation and integration lead. It owns the shared architecture, merges accepted work, runs checks and maintains the repository. Specialist agents receive bounded tasks with explicit file ownership and acceptance evidence: backend/data, interface/workflows, camera/integration, and independent security/test review. Use only the available concurrent capacity; more agents do not guarantee faster delivery, and concurrent edits to the same files are avoided.

Jawahir Q. owns product priorities, price, supplier decisions, customer communications and live-release acceptance. Pharmacy staff supply site inventories, operating procedures, authorised credentials, test participation and factual incident review. No dedicated computer, capture card, accelerator, camera, relay or new installation wiring is part of the project. Site staff or their existing IT contact enable authorised access to existing equipment. If it exposes no supported interface, that view is unsupported under the no-new-hardware scope. There is no assumed hired software engineer, QA employee or standing support team.

Package	Deliverable	Completion evidence
W1 Foundation	Repository, checked contracts, synthetic fixtures, simulator, threat model and local development setup	Reproducible setup and schema checks; customer/supplier discovery log
W2 Access and sites	Login, tenant/site isolation, roles, branch subscription record and commissioning registry	Real database permission tests and denied cross-tenant browser/API requests
W3 Complete workflow	Candidate review, benign dismissal, manual incident, evidence playback, tasks and closure	One reproducible end-to-end synthetic journey with failure and conflict cases
W4 Camera integration	Qualified adapter, leased companion capture, verified uploads, health and private routing	Supplier contract tests plus per-view stream and existing-laptop performance evidence
W5 Reports and controls	Assistance, factual AI drafts, exports, budgets, governance and operational metrics	Held-out draft evaluation, budget concurrency and evidence lifecycle tests

¹ Veesion. [Partner programme](#); Vision247. [Advertised deployment model](#); Solink. [API authentication](#). Commercial integration rights remain to be obtained.

Package	Deliverable	Completion evidence
W6 Release readiness	Retention, rights, restore, offboarding, security, deployment and operating runbooks	Critical release checks and measured recovery drill; no unresolved release blocker
Site commissioning	Training, local checks and shadow evaluation; allow one to two weeks when sites are ready	G2 to G4 evidence by site and enabled detector class
Live pilot	Eight weeks of measured operations after acceptance; extend if samples are inadequate	Weekly workload, coverage, value and actual company delivery cost

Work packages are sequence and acceptance boundaries, not two-week sprints. Re-estimate the next package after W3 gives measured implementation throughput. Supplier access, physical visits and the live observation period cannot be compressed by assigning more agents. A stalled adapter does not prevent synthetic workflow progress, but it does prevent acceptance of integrated live detection.

For each task, the lead records requirement IDs, owned paths, expected behaviour, test command and definition of done. A different agent reviews material authentication, tenancy, media, retention and physical-control changes. The lead reproduces relevant checks before committing. Shared model assumptions can still produce shared mistakes, so agent agreement never substitutes for actual test or site evidence.

Use small commits with a readable status record distinguishing planned, implemented locally, tested, pushed and deployed. Pushes are authorised to the supplied repository; a pushed commit alone does not establish a deployed application. Runtime accounts, commercial subscriptions, physical access and deployment configuration must be concrete before any live release.

4 Functional Requirements

The following requirements define observable behaviour and acceptance. Requirement IDs are stable across the delivery backlog and handover pack. MVP requirements apply to the core application; OPTION and P2 requirements are tracked but do not silently expand the first release.

Access

ID and release	Requirement	Required behaviour and acceptance
FR-001 MVP	Named accounts and MFA	Authenticate staff through managed OIDC; require individual accounts and authenticator MFA. Shared hardware never creates shared identity. Acceptance: Invalid issuer, audience, nonce, state and expired session tests fail; no browser-stored bearer token.
FR-002 MVP	Organisation and site access	Resolve active organisation from an authenticated membership and enforce permitted sites on every operation. Acceptance: Client A cannot read, change, infer or export Client B data; same-organisation unauthorised-site tests also fail.

ID and release	Requirement	Required behaviour and acceptance
FR-003 MVP	Invitations and role changes	Managers invite eligible roles only within their own authority; invitations expire after seven days and are one use. Acceptance: A setup operator cannot invite a manager; used or expired invitation fails; removal invalidates sessions and grants.
FR-004 MVP	Shift assignment and handover	Assign a named reviewer and alternate; hand over pending work explicitly; show missing coverage. Acceptance: An unassigned shift shows degraded reviewer coverage and routes privately to the configured alternate.
FR-005 MVP	Session controls	Use server-side opaque sessions, idle lock, CSRF validation and session revocation; reauthenticate privileged actions. Acceptance: Old tabs lose API/media access after revocation; cookie-authenticated mutations without CSRF fail.
FR-006 MVP	Support access grants	Grant support access to a specific site, purpose, scope and expiry; default access is operational metadata only. Acceptance: Expired grants fail; a health grant cannot view media or export; all grant use is audited.

Commissioning

ID and release	Requirement	Required behaviour and acceptance
FR-007 MVP	Site registry	Record legal entity, address, Europe/Dublin timezone, hours, contacts and pilot owner before activation. Acceptance: Each site has separate policies and status; Dublin daylight-saving boundaries preserve event ordering.
FR-008 MVP	Device enrolment	Exchange a one-use, ten-minute enrolment token and device-generated CSR for a site-bound credential. Acceptance: Token reuse, wrong site and revoked certificate fail; no factory shared password is accepted.
FR-009 MVP	Camera capability register	Record exact camera/recorder model, firmware, stream path reference, codec, view and approved event classes. Acceptance: Stream accessibility and detection qualification have separate results; unsupported views show a reason.
FR-010 MVP	Privacy masks and exclusions	Exclude consultation rooms, prescription screens, audio and unnecessary areas; version local capture policy. Acceptance: Masked areas remain excluded in inference input and uploaded review copies; scope changes require requalification.
FR-011 MVP	Local credentials	Keep camera secrets in the local protected credential store; cloud inventory holds opaque references. Acceptance: Secrets do not appear in logs, support bundles, URLs, exports, screenshots or source control.

ID and release	Requirement	Required behaviour and acceptance
FR-012 MVP	Activation gate	Activate a site only after role assignment, view tests, processing scope, notifications and commissioning records pass. Acceptance: Activation is blocked with named missing checks; one site's acceptance cannot activate another site.
FR-013 MVP	Coverage health	Measure frame freshness, camera decode, detector status, clock offset, laptop companion disk and connectivity separately. Acceptance: A frozen frame or missing detector never displays as active detection; healthy unrelated views remain visible.
FR-014 MVP	Maintenance and updates	Install signed, compatible laptop companion updates in stages with a previous-version rollback and local recovery procedure. Acceptance: Invalid signature, low disk or failed health check prevents promotion; restart does not erase command deduplication.
FR-067 MVP	Existing laptop only	Install the companion on the pharmacy's existing laptop and connect existing supported cameras or recorder software interfaces. No appliance, capture card, GPU, relay or new camera purchase is allowed. Acceptance: OS-specific install, startup, sleep/resume, disk/CPU guard, encrypted spool and laptop speaker tests pass; unsupported existing equipment is disclosed rather than replaced.

Detection

ID and release	Requirement	Required behaviour and acceptance
FR-015 MVP	Normalised observations	Validate source event ID, mapped camera, interval, model version, score scale, quality and evidence references. Acceptance: Unknown camera, unsupported schema/class and cross-site evidence fail; product and score may remain unknown.
FR-016 MVP	Idempotent intake	Deduplicate exact provider/device events transactionally using source identity and stable source event ID. Acceptance: Concurrent retries create one observation; a repeated ID with different content returns conflict.
FR-017 MVP	Qualified classes only	Enable concealment or sweeping only when the contracted detector and camera view pass site acceptance. Acceptance: No generic object detector or language model is presented as a validated concealment engine.
FR-018 MVP	Context and clip readiness	Send an eligible alert with available preceding context; attach following footage asynchronously with explicit readiness. Acceptance: Notification is not delayed for the full post-event clip; absent or corrupt media is clearly shown.
FR-019 MVP	Candidate grouping	Group a validated event sequence conservatively; preserve separate observations and uncertain associations. Acceptance: Nearby unrelated customers are not merged solely by location; grouping never creates cross-visit identity.

ID and release	Requirement	Required behaviour and acceptance
FR-020 MVP	Historical events	Preserve capture and arrival time; flag stale or uncertain-time observations as historical. Acceptance: Buffered events after reconnection cannot trigger an immediate sounder or inflate current latency metrics.
FR-021 MVP	Class controls	Version thresholds and routing by provider/model/site; allow a manager to suspend a noisy class. Acceptance: Suspension is audited and visibly reduces coverage; model changes rerun the agreed evaluation set.

Review

ID and release	Requirement	Required behaviour and acceptance
FR-022 MVP	Incident creation	Open a case from a reviewed candidate or a manual factual report; keep observation and incident identities separate. Acceptance: Manual reporting works without a detector; duplicate conversion of the same candidate is controlled.
FR-023 MVP	Review and classification	Capture benign, insufficient evidence, suspected incident or store-confirmed loss with reasons and supporting evidence. Acceptance: Only a manager records store-confirmed loss; no action creates a thief label or legal finding.
FR-024 MVP	Concurrent changes	Use expected record version for workflow, ownership, review and financial changes. Acceptance: Two reviewers cannot silently overwrite one another; conflict response supplies the current version.
FR-025 MVP	Outcomes and valuation	Record loss, recovery and payment outcomes separately using EUR minor units and an explicit cost basis. Acceptance: Unknown amount stays null; recovered goods and the same avoided loss are not counted twice.
FR-026 MVP	Follow-up tasks	Create tasks with assignee, due date and reason; closure identifies outstanding action ownership. Acceptance: Overdue tasks appear in the appropriate site inbox; closing the case does not silently discard tasks.
FR-027 MVP	Correction and reopening	Append corrections and manager reopening reasons while preserving prior versions and original observations. Acceptance: A corrected outcome updates reports and retains its audit trail; later evidence does not rewrite history.
FR-028 MVP	Restricted earlier-incident link	Permit an authorised manager to link a specific earlier case with an evidence-based reason and retention review. Acceptance: No automatic identity matching or shared watchlist is created; prior suspicion is not a new offence.

Evidence

ID and release	Requirement	Required behaviour and acceptance
FR-029 MVP	Upload lifecycle	Create a scoped upload intent, accept bytes, validate checksum/size/type and quarantine before publication. Acceptance: Oversized, mismatched or malformed media stays unavailable and produces a traceable failure.
FR-030 MVP	Original and derivative separation	Preserve collected source bytes and timestamps; generate separately labelled preview/redacted variants. Acceptance: A transformation never overwrites the original or its digest; manifest records parent and transform version.
FR-031 MVP	Controlled playback	Serve evidence through an authenticated, revocable media proxy with site/purpose checks and range support. Acceptance: Leaked URL, expired grant and wrong-site session cannot retrieve any byte range or thumbnail.
FR-032 MVP	Export preparation	Managers choose cases, recipient reference, purpose and permitted variants; a job builds the package. Acceptance: Export rechecks current authority and retention at execution and download; no automatic external sending occurs.
FR-033 MVP	Evidence manifest	Include selected originals/derivatives, hashes, UTC/local times, collection provenance, reviews and export history. Acceptance: An independent verification tool detects modified bytes; digest is not described as proof of guilt or admissibility.
FR-034 MVP	Retention and holds	Apply justified retention classes, reviewed holds and expiry to media, derivatives, exports and AI drafts. Acceptance: Concurrent hold/deletion is serialised; deletion failures block new access and alert the privacy owner.
FR-035 MVP	Rights requests	Record receipt, verified request scope, calendar-month due date, redaction review and authorised response. Acceptance: Month-end dates calculate correctly; search stays scoped; disclosure protects unrelated people.

Response

ID and release	Requirement	Required behaviour and acceptance
FR-036 MVP	Private notification routing	Use the staffed console first; optional push contains only a generic reference; remind at 30 seconds and escalate at 90. Acceptance: Duplicate dispatch is deduplicated; no acknowledgement never automatically becomes a public alarm or emergency call.
FR-037 MVP	Assistance request	Let an authenticated staff member request help without classifying an offence; distinguish delivery and acknowledgement. Acceptance: Repeated taps reuse one logical request; acknowledgement is not represented as responder arrival.

ID and release	Requirement	Required behaviour and acceptance
FR-038 MVP	Emergency continuity	Keep the pharmacy's established physical panic and emergency procedures independent of the cloud app. Acceptance: Loss of cloud, laptop companion or browser does not disable the existing physical panic arrangement.
FR-039 OPTION	Commissioned attention sounder	Permit an individually authorised person to request a mapped attention output after reviewing current context. Acceptance: Wrong site, missing permission, stale live context or incomplete commissioning blocks authorisation.
FR-040 OPTION	Safe command execution	Use one-use authorisation, signed commands, ten-second maximum TTL and a five-second maximum attention pulse. Acceptance: Replays, reboot and crash after dispatch cannot cause a second pulse; uncertain physical state stays unknown.
FR-041 OPTION	Local stop and output testing	Require a tested stop control for the documented existing software interface, output feedback policy and test mode isolated from live outputs. Acceptance: Expiry, duplicate, unavailable existing interface, watchdog and emergency-stop tests pass at each commissioned output.

AI

ID and release	Requirement	Required behaviour and acceptance
FR-042 MVP	Incident draft assistant	Draft only from reviewed structured facts and approved evidence references; identify missing fields explicitly. Acceptance: Schema failure or unsupported identities/amounts returns to manual completion; staff approval remains required.
FR-043 MVP	Job permissions and limits	Give each AI job a fixed input schema, model/prompt version, timeout, output limit and cost reservation. Acceptance: No AI job can execute shell/SQL, activate a sounder, disclose evidence or send a message externally.
FR-044 MVP	Spending and fallbacks	Enforce per-tenant model budgets atomically before calls; retry at most once and retain manual workflows. Acceptance: Budget exhaustion, timeout and supplier outage never block review, evidence capture or manual reports.
FR-045 MVP	Quality and change control	Evaluate report drafts on a held-out factual set before model/prompt changes and sample staff corrections. Acceptance: Critical unsupported assertions prevent release; improvements cannot be claimed from training examples alone.
FR-046 P2	Approved procedure assistant	Retrieve only current approved nonclinical procedures with source/version and a direct link. Acceptance: Missing or conflicting procedure yields no confident instruction; revoked documents disappear from retrieval.

Reporting

ID and release	Requirement	Required behaviour and acceptance
FR-047 MVP	Operational dashboard	Show coverage, pending reviews, task age, review time, unresolved cases and provider failures by authorised site. Acceptance: Totals reconcile to scoped records; missing observations and downtime remain visible.
FR-048 MVP	Financial reporting	Report documented cost-basis losses and recoveries separately from candidates and suspected incidents. Acceptance: No report totals guessed alert values as savings; reversals and corrections change the relevant period transparently.
FR-049 MVP	Weekly digest	Generate a deterministic aggregate first and optionally summarise it with AI; suppress sparse or unsupported trends. Acceptance: The report still works without AI; no person-level risk scores or cross-customer footage are included.

Governance

ID and release	Requirement	Required behaviour and acceptance
FR-050 MVP	Auditable actions	Append actor, purpose, resource, timestamps, request ID and relevant before/after version for sensitive actions. Acceptance: Runtime users cannot update/delete audit records; independently stored checkpoints reveal later changes.
FR-051 MVP	Processing controls	Record controller/processor responsibilities, permitted sources, offence-data safeguards and cloud processing settings. Acceptance: Live data activation requires completed site-specific records; project approval does not fabricate a legal basis.
FR-052 MVP	Customer offboarding	Export authorised records, revoke people/devices/integrations and apply deletion plus backup expiry. Acceptance: Terminated access fails immediately online; restored backups cannot revive deleted or revoked access.
FR-053 MVP	Sensitive feature exclusions	Provide no facial embeddings, cross-visit recognition, shared offender search, door-lock adapter or clinical decision tool. Acceptance: Contract, UI, database and permissions contain no hidden enabled route to an excluded feature.

Platform

ID and release	Requirement	Required behaviour and acceptance
FR-054 MVP	Durable work queue	Use committed jobs/outbox rows, leases, fencing tokens and bounded retries for uploads, exports and notifications. Acceptance: Worker crashes and expired leases do not lose committed work or duplicate final business effects.

ID and release	Requirement	Required behaviour and acceptance
FR-055 MVP	Database isolation	Use tenant-inclusive foreign keys, runtime RLS and transaction-local context; separately enforce site and action permissions. Acceptance: Wrong-tenant references fail; connection-pool reuse cannot retain the previous request's tenant context.
FR-056 MVP	Recovery and backups	Back up database/WAL and media independently; restore in isolation and reapply deletion and revocation records. Acceptance: Demonstrate a 15-minute database RPO and four-hour core-service RTO under the scoped pilot recovery test.
FR-057 MVP	Observability	Monitor latency, coverage, queue age, disk, failed uploads, model spend, permissions and export/deletion failures. Acceptance: Alerts identify the affected site/service without exposing video, camera passwords or incident narratives in logs.
FR-058 MVP	Release pipeline	Validate contracts and isolation, scan dependencies, sign immutable releases and promote through staging and a canary site. Acceptance: A failing critical check prevents deployment; rollback keeps previously committed incidents readable.
FR-059 MVP	Offline and degradation	Serve no cached sensitive media in the web service worker; laptop companion spools only within its signed capture lease and limits. Acceptance: Internet recovery labels old events historical; expired commands never run; unsupported offline functions say unavailable.
FR-060 MVP	Accessibility and usability	Support keyboard review, visible focus, readable text, non-colour status and labelled controls on the two existing laptops. Acceptance: A pharmacist can complete the core flow using keyboard or touch; sound is supplementary to visible notifications.

Stock

ID and release	Requirement	Required behaviour and acceptance
FR-061 P2	Read-only import	Accept approved nonclinical SKU movements and counts through validated files or an agreed API; reject patient and payment data. Acceptance: Wrong site, ambiguous units, duplicated batches and invalid rows are rejected or quarantined with an import report.
FR-062 P2	Complete reconciliation	Calculate expected stock from opening count and all relevant movement classes; display missing inputs and source watermark. Acceptance: Incomplete periods cannot produce a definitive theft claim; batch context never supports live nonpayment conclusions.

ID and release	Requirement	Required behaviour and acceptance
FR-063 P2	Stock investigations	Create a task for recount, delivery, return, transfer, damage or expiry review and record the supported explanation. Acceptance: A variance cannot be automatically assigned to a shopper or employee; source corrections remain versioned.
FR-064 P2	Expiry and recall coordination	Match exact approved product/batch data, assign action and require pharmacist confirmation where applicable. Acceptance: Stale notices or absent batch data show unknown; AI cannot infer availability or order a substitution.
FR-065 P2	Aggregate forecasting	Forecast workload or incident counts by sufficiently aggregated zone/time with exposure and uncertainty. Acceptance: Below the minimum data threshold show insufficient evidence; no personal criminality or clinical forecast is produced.

Commercial

ID and release	Requirement	Required behaviour and acceptance
FR-066 MVP	One branch subscription and AI budget	Record exactly 6000 EUR cents monthly for one pharmacy branch; bind the subscription to its company and site, with a EUR 5 branch model allowance. Billing begins as an owner-managed record. Acceptance: Creating a branch cannot charge a customer or enable paid capacity automatically; a separate approved subscription or explicit trial is required, and unknown tax terms cannot publish a checkout.

5 Screen Design and User Journeys

Use an installable responsive web application with one primary review queue. The existing Windows and Mac laptop browsers are the primary supported surfaces. Other already-owned devices are optional. Push on a personal phone is supplementary. Do not cache video, incident text or authentication data for offline use in the browser service worker.

Screen	Information and actions	Required states
Sign-in and organisation selection	Managed login, MFA, accessible account recovery and authorised organisation switch	Signed out, expired session, locked account, no membership
Shift start and home	Named reviewer, alternate, coverage by view, unreviewed events and overdue tasks	Ready, no reviewer, partial coverage, cloud disconnected
Review queue	Site/view, observed-event label, source/arrival time, clip readiness and assignment	New, acknowledged, grouped, historical, unavailable media

Screen	Information and actions	Required states
Event review	Preceding context, developing/final clip, uncertainty, acknowledge, classify and request help	Loading, insufficient context, conflicting review, corrected outcome
Incident detail	Timeline, facts, reviews, tasks, values, evidence, draft and approved report	Open, under review, closed, reopened, retention restricted
Evidence viewer	Authorised variant, capture interval, source, checksum and redaction status	Available, quarantined, expired, held, unsupported format
Export form	Selected cases/variants, recipient reference, purpose, expiry and approval	Queued, validating, ready, revoked, failed, expired
Assistance	Location, request reason and delivery/acknowledgement state	Sending, active, acknowledged, cancelled, expired
Manager reporting	Coverage denominator, review time, classification totals, outstanding tasks, documented values	Current, incomplete period, insufficient evidence, stale source
Site commissioning	Inventory, privacy exclusions, view tests, notification tests and activation checks	Draft, blocked, qualified, active, suspended, decommissioned
Governance and support	Memberships, temporary grants, retention, holds, rights requests and device health	Restricted by role; actions show scope and expiry
Optional sounder	Site/output identity, current live context and explicit deliberate activation	Disabled, unauthorised, context stale, sent, verified, unknown

Primary journey: staff signs in and accepts duty; a qualified observation creates a review item; the console signals privately; a reviewer acknowledges and examines context; the reviewer dismisses or opens an incident; a manager records supported outcomes; evidence and follow-up are completed; the incident closes with an audit trail. No classification is inferred from closing the case.

An alert can display preceding context before all following footage exists. Show the available interval and update the clip when finalised. If staff see an item returned to the shelf or payment context that clears the concern, retain the correction and update the reporting aggregates. An insufficient-evidence outcome is a valid completion, not a system failure.

Manual assistance is independent of a theft classification. Staff must be able to request a colleague without completing an incident form or waiting for AI. The app reports receipt and acknowledgement separately; emergency response continues to use the site's existing physical panic and operating procedures.

All destructive or sensitive forms show the exact site and resource. Restore keyboard focus after dialogs, label icons, retain a visible loading/error state and offer an ordinary manual path when media or AI is unavailable. Never use red/green colour alone to communicate coverage or authority.

6 Identity Permissions and Tenant Isolation

Use managed OIDC authentication, with Amazon Cognito Essentials in eu-west-1 as the planning baseline subject to commercial and processing terms. FastAPI acts as the browser backend. Use authorization code with PKCE,

state and nonce; validate issuer, audience and signatures; hold provider tokens encrypted on the server. The browser receives an opaque Secure, HttpOnly, SameSite=Lax cookie. Session and CSRF controls remain application responsibilities. ²

Proposed session limits are eight hours absolute and fifteen minutes idle, with a quick lock suitable for shared hardware. Privileged exports, role changes and sounder authorisation require recent authentication under a five-minute freshness policy. Revoking a membership invalidates online sessions, media grants and pending authorisations. The identity provider authenticates a person; the AisleSignals database decides their organisation, site and action authority.

Role	Routine permissions	Additional restriction
Reviewer	Assigned-site alerts, factual notes, assistance, reviews and task completion	Cannot confirm financial loss, export originals or change retention
Pharmacy manager	Site administration, loss classification, corrections, approved exports and duty routing	Sounder use requires an additional explicit capability
Group owner	Authorised group sites and aggregate reports	Does not gain another customer's records
Privacy administrator	Rights requests, retention, reviewed holds and disclosure governance	No sounder authority from this role alone
Setup operator	Time-limited commissioning, device tests and operational health	No historical incidents or routine footage browsing
Support engineer	Health/configuration metadata under a scoped grant	Media access requires a separate purpose-limited grant
Platform operator	Infrastructure and organisation provisioning	No standing application-level customer media permission

Every database transaction establishes server-validated tenant context and clears it when the transaction ends. Use tenant-inclusive unique keys and foreign keys. Runtime database roles are not table owners and have no BYPASSRLS or migration privileges. Enable and force row-level security on tenant business tables; application checks additionally enforce permitted sites, resources and actions. RLS does not replace those checks, and privileged database access remains a controlled operational responsibility. ³

Apply the same checks to search, counts, thumbnails, byte-range playback, exports, background jobs, links, metrics and support tools. Return a generic not-found result for another tenant's object; do not reveal existence through a different error message. Cache keys include tenant, site, user capability and relevant policy version. Never accept a tenant header as authority without validating the authenticated membership. Object-level authorisation is a first-class test category. ⁴

² AWS. [Cognito security best practices](#), [regional endpoints](#) and [pricing](#). Identity, email, SMS and machine-identity charges must be evaluated separately.

³ PostgreSQL. [Row Security Policies](#), including owner/privileged-role behaviour and foreign-key considerations.

⁴ OWASP. [API1 Broken Object Level Authorization](#), API Security Top 10 2023.

7 Architecture and Repository Design

The recommended structure is a modular monolith: React/TypeScript client; Python FastAPI API; separate Python worker processes using the same domain package; PostgreSQL; private EU object storage; and a bundled Python camera companion on the existing pharmacy laptop. React can be assembled with Vite and explicit routing/data-fetching libraries; it does not require server rendering for this authenticated operational console. ⁵

Build the pharmacy workflow, permissions, evidence lifecycle, adapter contract, operational controls and reporting. Reuse authentication, storage, email delivery, established video decoding and a contracted detection engine. Avoid building a foundation model, identity provider, codec, pharmacy dispensing system or a large autonomous-agent runtime.

Existing pharmacy cameras or recorder

- > Companion software on the existing pharmacy laptop
- > Normalised event and authorised clip transfer
- > FastAPI intake -> PostgreSQL business records and outbox
- > Durable worker -> Private evidence storage and notifications
- > Authenticated pharmacy web console -> Human review and outcome

Optional reviewed facts -> Budgeted AI job -> Staff-approved draft

Optional staff authorisation -> Signed expiring command -> Site output

P2 approved stock feed -> Validated import -> Reconciliation and tasks

The control plane manages sites, identities, permissions, devices and signed policies. The event plane accepts source observations and queues work. The media plane validates uploads and serves authorised variants. The action service is a separate logical module with a narrowly allowlisted output vocabulary. It does not share the AI job's credentials or permissions.

Use a single repository with apps/web, services/api, services/worker, services/companion, packages/contracts, adapters/detectors, adapters/stock, infra and tests. Shared domain logic lives in a Python package imported by API and workers; generated TypeScript types derive from the checked OpenAPI contract. Keep a simulator adapter and synthetic tenant fixtures available from W1.

Pin supported runtime and dependency versions with lockfiles and immutable image digests at kickoff. Avoid floating latest tags. Backend validation uses Pydantic models; database changes use reviewed Alembic migrations; the client uses explicit query caching and invalidation. A deployment does not automatically approve a detector model or a camera view.

8 Domain States and Data Model

Separate raw observations, review candidates, incidents and reviews. An observation is a detector or staff-supplied factual record. A candidate groups a supported event sequence for review. An incident is a managed case. Reviews are append-only decisions; the incident stores the latest materialised summary and version. Candidate detail exposes authorised evidence references. A candidate-specific access grant allows playback and benign dismissal before an incident exists; the same user, site, expiry and media-proxy checks apply.

Incident workflow is NEW, ACKNOWLEDGED, UNDER_REVIEW, CLOSED or REOPENED. Classification is independently UNASSESSED, BENIGN, INSUFFICIENT_EVIDENCE, SUSPECTED_INCIDENT or STORE_CONFIRMED_LOSS. Outcomes separately record UNRESOLVED, NO_LOSS_ESTABLISHED, GOODS_RETURNED, GOODS_PAID_FOR, STOCK_DISCREPANCY or LOSS_RECORDED. Closure requires a reason and any outstanding task owner; it does not imply a confirmed offence.

⁵ React. [Build a React App from Scratch](#); FastAPI. [Containers and Docker](#).

Entity family	Principal fields	Required constraints
Organisations and memberships	organisation_id, user subject, roles, allowed sites, status, version	Unique membership; validated role delegation; immediate revocation
Sites and cameras	organisation/site/camera IDs, name, hours, zone, device mapping, qualification, policy version	Tenant-inclusive references; exact source mapping; no cloud camera password
Devices and configuration	device ID, credential fingerprint, boot ID, sequence, lease, version, revocation	One site per device; unique credentials; signed versioned policy
Observations and candidates	source ID, source event ID, capture interval, arrival, class, score scale, model, quality, evidence IDs	Unique source event; null allowed for unknown facts; conservative grouping
Incidents reviews and tasks	state, classification, outcome, version, assignee, reason, cost/recovery, due time	Append-only reviews; optimistic locking; site-scoped ownership
Evidence and exports	asset ID, variant, object key, bytes, digest, source interval, parent, lifecycle, recipient/purpose	Private key mapping; immutable collected bytes; retention and access gates
Holds and rights requests	resource scope, owner, reason, received date, review/due date, decision	Reviewed expiry; calendar-month rights due date; controlled disclosure
Notifications and assistance	effect key, recipient/device, channel, sent/delivered/acknowledged, expiry	Delivery is not acknowledgement; deduplicated logical effects
AI jobs and usage	input references, model/prompt version, reservation, actual cost, result status	No arbitrary tools; atomic budget reservation; versioned draft
Action authorisations and commands	actor, output, live context, nonce, deadline, policy, execution/feedback	One-use authorisation; at-most-one dispatch; unknown physical state represented
Jobs outbox and audit	lease token, attempts, available_at, effect key, request/trace ID	Transactional business/outbox write; fenced completion; restricted audit mutation
P2 stock records	feed, SKU, units, source version/watermark, movement type, count	Idempotent batches; complete movement equation; no patient/card fields

Use UUIDs for public identifiers, UTC timestamps for ordering and Europe/Dublin for display and business schedules. Store money in integer EUR cents; quantities use an explicit unit and decimal precision. Null means unknown and must not be converted to zero. Preserve source time and companion/server arrival time separately when clocks disagree.

Index tenant/site plus event time for incident queues, source identity plus source event ID for intake, lifecycle plus expiry for retention, status plus available_at for jobs, and actor/resource/time for audit. Partition only when measured size or maintenance requires it. The data dictionary in the pack enumerates attributes, relations and lifecycle decisions; schema migrations must implement these constraints before live data is enabled.

9 API and Event Contract

The revised OpenAPI design uses /v1 business routes and browser sessions. Design version 2.2 supersedes the earlier draft contract; no production migration is implied because the prior design was not a deployed service. Auth callbacks and supplier-specific raw webhook formats remain separate from normalised business payloads.

Every mutation validates an explicit request model, current authority and relevant expected_version. Idempotency-Key is required for retrievable creations, reviews, uploads, exports, imports and commands. Store the actor/source scope, route, key, canonical request digest and resulting resource atomically. An identical retry returns the same result; changed payload under the same key returns 409. Ordinary keys persist for 30 days. Command IDs and dispatch records persist for the full command audit window.

API area	Main operations	Behaviour
Session and organisation	Session read, logout, active-organisation change, organisation/site listing and controlled provisioning	Server-owned scope; no client-selected tenant authority
Membership and commissioning	Invitations, role updates, site/camera configuration, device enrolment, check records, activation	Role delegation, one-use enrolment and recorded acceptance
Events and incidents	Observation intake, candidate queue, incident creation/read, transitions, review, assignment and tasks	Source deduplication, explicit state machine and version conflicts
Evidence and exports	Upload initiation/completion, metadata, access grant, media proxy, export job and revoke	Validation/quarantine, protected playback and current-authority recheck
Operations and governance	Health, policy revision, shift assignment, assistance, retention holds, rights and support grants	Scoped permissions and auditable policy changes
AI and reports	Draft job, result review, usage, operational/financial aggregates	Human approval, atomic spend limits and deterministic totals
Optional actions	Live-context session, output listing, authorisation, command, feedback	Separate role and commissioning gate; no arbitrary action string
P2	Stock import and import result, discrepancy review	Read-only source access; incomplete data explicitly represented

Use opaque cursor pagination with a default of 25 and maximum of 100 records. Stable ordering includes timestamp and ID. Return a request ID on every response. Use 401 for absent authentication, 403 for denied same-scope action, 404 for invisible resources, 409 for version/idempotency conflict, 422 for failed business preconditions, 429 for rate/cost limiting and 503 for unavailable dependencies. A 202 response means queued or accepted, never physically completed.

The browser receives a resumable SSE stream of authorised record references, not evidence bytes. Last-Event-ID allows refresh after interruption; a gap outside retention triggers a fresh list query. A 15-second polling fallback maintains state when SSE fails. Media remains an authenticated request. Reconnect does not mark an old incident as current.

Companion traffic uses a site-bound certificate and short-lived device token. After one-use enrolment, the certificate alone authenticates POST /v1/device/token; an existing bearer is not required. Issue a certificate-bound token for at most ten minutes and renew after five. Rotate the thirty-day certificate seven days before expiry, with at most twenty-four hours of overlap. Expired or revoked certificates require supervised re-enrolment. Token exchange and every subsequent request check current device/site status; a cached token does not override revocation. Integration services use separately scoped machine credentials after supplier signature validation. Raw vendor URLs are never accepted as arbitrary fetch destinations. A configured adapter resolves a trusted vendor media reference through an allowlisted endpoint, or receives uploaded bytes.

10 Existing Laptop Camera Connection and Adapter

Inventory the actual recorder, cameras, firmware, available stream channels, codecs, bitrate, connection limits, clock source, network ownership and maintenance contract. The qualification result distinguishes accessible, decodable and suitable-for-class. ONVIF Profile T defines useful streaming and event capabilities, including conditional features; it does not establish universal camera or analytics compatibility.⁶

Install a lightweight companion on the pharmacy's existing laptop. The companion connects to existing cameras or recorder streams, packages permitted events and talks outbound to the hosted API. The web dashboard handles review and administration. There is no purchased appliance, capture card, GPU, relay or new camera. Browser access to a CCTV vendor page alone does not prove the native software can obtain its video stream.

Prefer an authorised RTSP/ONVIF network path already reachable from the laptop, or a documented recorder/vendor software interface. A directly connected existing USB camera is a separate, explicitly selected source with its own permissions and view qualification. Do not switch on the laptop's built-in webcam by default. An HDMI recorder output is not a usable laptop input without suitable existing capture capability; buying an adapter is outside scope. Locked proprietary systems remain unsupported for live analysis, with manual authorised clip import as a limited workflow option.

The shared Python companion core contains enrolment/configuration, source supervision, privacy masks, bounded event buffer, detector adapter, encrypted SQLite spool, uploader, health and signed updater. Package a self-contained runtime with platform-specific builds so pharmacy staff do not need Python or Docker. Use a signed Windows installer and a signed/notarised macOS bundle for the platforms actually selected and tested. PyInstaller builds are OS-specific; do not assume one binary covers both platforms. Platform signing-account and certificate costs are software-distribution inputs, not hardware purchases.⁷

The pilot is confirmed to include one Windows laptop and one Mac. Both operating-system packages belong in the first pilot release, using the same core and separate platform adapters. Record their actual OS versions and processor architectures before freezing build targets; do not assume every Windows or macOS version is supported. Neither package is yet built or shipped. On each chosen OS, provide a visible tray/status application and a least-privilege background component. Normal startup is at approved user sign-in; operation before sign-in requires a separately accepted service configuration. The local settings surface binds to loopback only, checks origin and a per-session secret, and exposes no general file, shell or network proxy. Keep camera credentials in the OS-protected store with private-key and spool permissions scoped to the application identity.

Start qualification with one or two supported views and existing decode acceleration when available. Benchmark during normal pharmacy work: aim initially for companion memory below 1 GB and aggregate CPU below 25% of laptop capacity, subject to measured detector requirements. Stop or reduce unaccepted classes if the pharmacy software slows, disk is low or thermal throttling appears. These are proposed acceptance limits, not a universal

⁶ ONVIF. [Profile T](#); FFmpeg. [RTSP protocol support](#). Stream access is not theft-detection validation.

⁷ PyInstaller. [Operating mode and platform-specific bundles](#); Apple. [Developer ID signing and notarisation](#). Packaging and distribution accounts require separate setup.

laptop specification. Never silently lower sampling below the detector's accepted rate or move full streams to paid cloud analysis to conceal overload.

The laptop must be powered on and awake during agreed coverage. Closing the lid, sleep, shutdown, sign-out or critical battery events may stop monitoring and local audio. Display this clearly; do not change power policies silently. Save spool state on normal suspend, tolerate abrupt suspension without a final heartbeat, mark the cloud status stale, and on resume recheck clock, certificate, lease and stream freshness before returning to active. Monitoring mode may request that the laptop remain awake only through a user-visible setting. Persistent operation cannot be promised while the host sleeps.⁸

The adapter interface provides capabilities, health and normalised observation delivery; stream registration and clip analysis are optional capabilities. Record which event classes, timestamps, confidence scale, media intervals and model versions are actually available. Scores from different providers are not directly comparable. If there is no supported event/media interface, the integrated release remains blocked at G1.

Start with a ten-second preceding buffer and a final event clip target of thirty seconds total where permitted and available. Notify on the available segment and attach following context later. Preserve collected source bytes; produce a separately labelled H.264 review derivative when source codec/browser compatibility requires it. Decoder and transcoder failures run in isolated subprocesses with resource limits.

Emit a heartbeat every sixty seconds, including feed freshness, decoder/detector availability, clock offset, queue depth, disk, software and policy version. Mark a companion degraded after two missed heartbeats and offline after three. A browser connection failure is shown immediately. Camera-local failure can be detected sooner, but cloud visibility remains bounded by its reporting path.

Use a signed capture lease valid for at most fifteen minutes, renewed during healthy connectivity. If disconnected, the AisleSignals companion may retain permitted queued observations and finish allowed local work only within that lease; after expiry it stops new AisleSignals capture and marks analytics unavailable. The pharmacy's independent CCTV recorder continues under its own configuration. Supported external software interfaces have separately verified outage behaviour. This avoids claiming unlimited offline detection.

Bound the encrypted spool by age and capacity, initially 24 hours and 2 GB, subject to available disk and site testing. Keep at least 5 GB of free host disk as an initial guard; if that reserve is unavailable, stop new media collection and show the gap. Reserve health/audit space. Expire eligible disposable buffers first; never silently overwrite held evidence. Original event IDs, sequence numbers and timestamps survive reboot. Reconnection uploads idempotently, reports any missing media, and labels delayed events historical. The upload owner polls GET /v1/uploads/{upload_id} until COMPLETE returns the committed evidence ID and verified digest. Release the local spool copy only when safe_to_release_spool is true and the digest matches; HTTP 202 is not a persistence acknowledgement. Rejected or expired uploads remain subject to the local retention limit and an explicit failure record.

11 Evidence Storage Export and Retention

An authorised actor or device requests an upload intent with site, source, expected content type, byte count and checksum. The service allocates an unpredictable private key and a short-lived upload capability. Completion verifies the actual object, size, digest and safe media decode before marking it available. User-supplied MIME type alone is insufficient. Unreferenced uploads expire through a separate cleanup job.

Original, preview, redacted and export objects have distinct IDs. A redacted or resized clip is never called an original. If masking occurs before collection, identify the collected asset as a masked-source recording; the

⁸ Microsoft. [System power management events](#). Suspend can interrupt processing and may occur without normal notification.

platform cannot claim to preserve pixels it never received. Do not collect prohibited consultation or prescription-screen areas in the first place.

Play clips through an authenticated media proxy. A maximum sixty-second access grant is bound to actor, site, asset, variant and purpose. Recheck current session, role, lifecycle and hold rules at every request, including range requests. Private object keys and signed storage URLs are not displayed as permanent download links. Browser responses use no-store where appropriate; revoke grants when authority changes.

Record class	Initial design default	Required handling
Short rolling buffer	Up to 60 seconds, overwritten if not part of an allowed event	Site processing purpose and excluded areas govern collection
Unreviewed candidate media	72 hours	Expire with derivatives unless converted to a justified case or held
Benign or cleared media	24 hours after disposition	Retain only minimal justified disposition metadata
Incident evidence and draft	90 days from case event unless justified schedule/hold requires otherwise	Review before extension; no indefinite default
Prepared export	Download availability up to seven days	Current access rechecked; recipient/purpose retained in audit
Minimal security audit	Twelve months	Exclude raw footage, credentials and unnecessary narrative
Backups	Maximum 35 days in this baseline	Reapply deletion and revocation records before restored service is exposed

These are configurable engineering defaults requiring the pharmacy's documented justification, not statutory universal retention periods. A hold has scope, reason, owner, next review date and end condition; review at least every thirty days. Serialize hold and deletion decisions so a race cannot erase protected evidence or extend unrelated records.

The export job produces selected media, a readable chronology and a machine-readable manifest with SHA-256 hashes, provenance, timestamps, transformations and approval. Hashes detect changes after collection; they do not prove scene authenticity, identity or admissibility. Recheck permission when building and downloading. Downloading is user-initiated; the application does not automatically email Gardaí or other recipients. A downloaded external copy cannot be technically recalled by revoking the platform link.

Rights requests record receipt time, verified scope and an ordinary due date one calendar month later, with reminders and qualified review of any extension or exception. Use calendar arithmetic, including month-end cases. Redaction and disclosure review protect unrelated people. A deletion tombstone ledger must be recoverable separately from an older database backup.

12 Notifications Assistance and Optional Alarm Control

On-duty console delivery and a private sound through the existing laptop speakers are the primary operational channels. Provide a visible sound self-test and staff confirmation at shift start; muted audio, blocked playback and Do Not Disturb never count as verified staff notification. The native companion can play the approved private alert

when the browser is backgrounded, deduplicated by notification ID. No microphone recording is needed. Optional web push and transactional email carry a generic reference without a person's image or allegation. Notification preferences cannot remove the site's required primary review route. Store separate submitted, sent, delivered where known, acknowledged, failed and expired timestamps.

Write notification intent and the related business change in one transaction. Use a stable effect key per incident, routing step and recipient. Remind privately after thirty seconds and notify the alternate after ninety seconds, configurable within the site policy. Cancel redundant escalation when the case is acknowledged. Queue age and recipient availability determine whether an event is historical rather than urgent.

Assistance requests are scoped to a site/location and a named requester, with bounded retry and cancellation. An acknowledgement does not prove a responder arrived. If the application is unavailable, staff follow the existing local response procedure. Do not add an automatic emergency call as a fallback.

An optional already installed attention sounder is supported only through its documented software interface, with a separate action service and companion executor. No new relay, wiring or alarm hardware may be bought or installed. If the existing interface cannot enforce bounded duration, safe expiry and duplicate protection, disable this option and retain laptop alerts. An authenticated live-context session obtains newly received source frames and records server/companion freshness and clock health; the browser cannot assert freshness by sending its own timestamp. Authorisation binds actor, session, site, output, action, linked review, context and policy. The context must be at most fifteen seconds old and the one-use token lives at most ten seconds. The cloud creates a one-use camera/device/nonce challenge with a ten-second deadline. The companion polls outbound every second in commissioned control mode and submits a bounded JPEG, source sequence, capture time and digest. The server checks authenticated source, challenge time, clock health and advancing decoder sequence; it supplies a private frame to the requesting session. Challenge reuse never refreshes an old context. Transient context frames expire within sixty seconds, independently of the shorter authority window.

The command transaction consumes that token and writes the signed command plus outbox entry atomically. The delivery contract carries a compact signed JWS with a fixed ES256 algorithm and a recognised key ID from signed device configuration. Its verified payload binds command, device, site, output, action, pulse duration, context, authorisation, policy, issue/expiry times and nonce. The companion rejects unknown algorithms/keys and remote key URLs, and checks its site, output allowlist, policy, credential status, clock health and absolute expiry. Use a one-second maximum clock-offset tolerance and a conservative remaining-time guard; reject uncertain time. Pulse duration is 100 to 5,000 milliseconds for the attention output only. The pharmacy's existing certified panic/intrusion system remains independent.

Command transport may deliver more than once; physical dispatch must not. Persist execution intent and the stable command ID before writing to the output. After a crash at an uncertain point, report UNKNOWN and use feedback or local inspection. Do not retry with a new ID to guess whether a pulse occurred. Store terminal states SUCCEEDED, FAILED, EXPIRED or UNKNOWN separately from physical feedback VERIFIED_ACTIVE, VERIFIED_INACTIVE, NOT_OBSERVED or UNKNOWN.

Commission test mode, output mapping, local stop, maximum pulse, watchdog, duplicate command, expired command, wrong site, no feedback, disconnection and reboot. A test command must use a simulator or the existing system's accepted test interface and must not accidentally activate a live alarm. A cloud or API receipt must never be displayed as confirmed physical activation. No adapter may control exit locks or obstruct escape.

13 Bounded AI Jobs and Cost Controls

Start with incident-report drafting and an optional weekly narrative over deterministic aggregates. The model receives only approved structured facts and necessary authorised references. Vision assistance is optional and

separately evaluated; a generic image description does not establish concealment, payment status, intent or identity. A reviewed-report workflow must remain useful with the model switched off.

Each job includes job_type, tenant/site, actor, source record/version, allowed facts, model/prompt version, maximum input/output tokens, deadline, cost reservation and expected JSON schema. The output includes draft text, source field references and unresolved questions. It cannot create actions, query arbitrary SQL, browse arbitrary pages, run code or choose a recipient. Treat uploaded text and images as untrusted data.

Reserve estimated maximum cost transactionally before invoking the provider; release unused reservation when actual usage is known. Initial model allowance is EUR 5 per subscribed branch monthly for the stated pilot workload, with warning at 80% and a hard stop at 100% unless an authorised budget change is recorded. Provider invoices remain in their billed currency; document the conversion used for reporting. Concurrency limits prevent simultaneous workers exceeding the cap.

Use one retry for a recoverable provider or schema failure. A persistent failure leaves a manual form and a clear status, not an invented report. Do not automatically escalate to an expensive model. A human may approve a separately budgeted escalation after reviewing its purpose. Record tokens, model, prompt version, latency, result and correction rate without duplicating unnecessary sensitive content in logs.

The earlier worked cost example uses GPT-4.1 mini's standard rates and selected frames, rather than continuous video analysis. Official pricing and image token rules support that calculation, but actual job mix, provider terms and model quality must be checked when implementation versions are frozen. API data controls require deliberate configuration; application storage flags alone do not settle all provider retention.⁹

Create at least 100 synthetic or appropriately de-identified report cases covering absent identity/value, conflicting notes, uncertain source timing, returned goods, aggression, missing media and prompt injection. Split by scenario/source, not duplicate text. Require no critical invented identities, financial amounts or unsupported criminal conclusions in the held-out release set. Human approval remains mandatory even after a clean test. Track median editing time and substantive correction rate during the pilot.

14 Stock Operations and Later Extensions

P2 begins with a read-only, authorised file or API feed for nonclinical product movements and counts. Required data includes site, source/batch/version, SKU, quantity/unit, event time, movement type and source watermark. Reject prescription, patient, loyalty and payment-card fields. A mapping profile explicitly defines signed quantities, product identifiers and reversals; do not infer the format from column position.

Expected closing units equal opening units plus receipts, transfers in and saleable returns, minus completed sales, transfers out and authorised write-offs. Compare with a reliable closing count. If any movement category or period boundary is missing, display incomplete reconciliation. A stock difference is an investigation item, not proof of theft or employee misconduct.

Validate an import into staging, report rejected rows and require a manager to accept the mapping. Deduplicate batch/file hashes and source row/version IDs. Correct source data through a revision or reversal. Batch data stays labelled batch; it cannot support a real-time claim that a particular person has not paid. A sale of the same SKU nearby in time does not establish shopper identity or payment association.

An investigation has owner, due date, recount/delivery/return/transfer/waste checks and a supported resolution. No write reaches the pharmacy's live till or dispensing database. Source availability, fees and refresh frequency

⁹ OpenAI. [GPT-4.1 mini](#), [image-input guide](#) and [API data controls](#).

are contractual dependencies; existing integrations advertised by pharmacy data suppliers do not confer our own access rights.¹⁰

Procedure retrieval indexes only approved nonclinical documents with owner, version, effective date and withdrawal. Recall/expiry tasks need exact permitted product/batch data and pharmacist review. Shortage coordination records verified status and timestamps, not invented stock availability or substitutions. Aggregate forecasting requires adequate history, exposure and uncertainty; introduce it only after useful data exists.

15 Security Privacy and Audit Controls

The pharmacy generally controls its operational data and AisleSignals processes it under agreed instructions; the actual roles, subprocessors and purposes must be documented. Incident records containing allegations can engage offence-data requirements from the first release. The site's assessment covers CCTV purpose, necessity, retention, access, rights, staff notice, cloud processing and supplier reuse. Ordinary project approval does not substitute for those deployment records.¹¹

Separate customer, support and platform permissions. Restrict database/network access, encrypt backups and storage, keep secrets in deployment/device secret stores, rotate credentials and verify signed companion updates. Log identifiers, timings and error codes rather than footage, camera URLs with credentials, tokens or narrative. Suppress authentication callback parameters from ordinary access logs.

Apply request limits, upload byte/type limits, decompression/decoder limits, private media keys, CSRF and origin checks, secure session cookies and least-privilege service identities. Do not expose camera endpoints as a generic proxy. Supplier callback verification includes signature, timestamp tolerance, replay prevention, mapped source and payload schema. Test malicious metadata, prompt injection, oversized media and mixed-tenant references.

Audit role changes, logins/revocations, evidence access, exports, holds, rights decisions, review corrections, policy changes, support grants and action commands. Runtime users append but cannot update/delete audit events. Write independently stored signed checkpoints or equivalent protected copies. A hash chain alone cannot defeat an administrator who can rewrite both the data and its checkpoint.

For a suspected data incident, restrict affected access, preserve necessary evidence, notify the controller without undue delay and support the applicable notification assessment. Use a one-hour internal escalation target and record awareness time. The controller's regulatory obligations, including applicable 72-hour breach notification rules, are assessed against the actual incident. Do not automate a legal conclusion or notification to the regulator.¹²

Backups and full administrative access are exceptional privileges with named operators and an access trail. Customer records are not used for model training by default. Any future recognition or clinical expansion requires a new scoped assessment and design; no dormant face index or clinical decision permission is included in the current contract.

16 Durable Jobs Concurrency and Failure Handling

Use PostgreSQL jobs and outbox tables rather than relying on in-process background work for durable effects. Claim jobs with short transactions and FOR UPDATE SKIP LOCKED; write lease owner/token, expiry and attempt count, then commit before external I/O. Fencing tokens prevent an expired worker committing a result over a newer owner. FastAPI background tasks are not the durable delivery mechanism.¹³

¹⁰ RWA. [Pharmacy partners and integrations](#). Listed integrations do not establish AisleSignals access rights or fees.

¹¹ Irish DPC. [CCTV guidance](#) and [DPIAs](#); Irish Data Protection Act 2018. [Section 55](#).

¹² European Union. [GDPR](#), particularly data-subject rights, processor duties and personal-data breach provisions.

¹³ PostgreSQL. [SELECT and SKIP LOCKED](#); FastAPI. [Background Tasks](#).

Notification, export, media validation, AI and deletion jobs use separate type-specific concurrency limits. Notification/control queues have separate priority from exports and AI. Ordinary work retries with bounded exponential backoff and jitter, then enters a visible failed/dead-letter state. Operator replay revalidates current permissions, lifecycle and idempotency; it does not blindly restore an old action.

Alarm commands follow their stricter no-redispatch rule and absolute expiry. An outbox retry may repeat delivery of the same command ID, but the device's persistent ledger prevents another pulse. Other external services may only provide at-least-once delivery; record that limitation instead of promising exactly-once effects across a network.

Failure	Immediate behaviour	Recovery condition
Camera frozen or moved	Mark that view unavailable/unqualified; stop claims for affected classes	New stream and view qualification
Companion or internet unavailable	Show stale health; bounded leased local work and spool; no remote sounder	Reconnect, reauthenticate, renew policy and replay only eligible data
Supplier/model unavailable	Detector coverage unavailable; manual reporting remains	Provider health and version checks pass
Object upload fails	Event shows missing evidence; quarantine/incomplete status	Verified retry within lifecycle and budget
Database unavailable	API fails clearly; companion retains permitted spool	Recover database, apply journals and reconcile idempotently
Worker crash	Lease expires; eligible work reclaimed with fencing	No duplicate final business effect
AI cap or timeout	Manual report remains available	Explicit budget change or successful bounded retry
Expiry deletion fails	Block new access and exports; alert privacy owner	Object/derivative deletion verified
Sounder status uncertain	Show UNKNOWN; prevent blind retry	Physical feedback or local inspection

17 Test Strategy and Two Site Acceptance

Maintain requirement-to-test traceability. Unit tests cover state transitions, money/quantity rules, calendar deadlines, grouping, command expiry and budget reservations. Integration tests use a real PostgreSQL service and private test object storage, with both client organisations and multiple sites in one organisation. Browser tests exercise the actual review, export, handover and failure interfaces.

Test negative authorisation on every object path and variant, including jobs, candidate counts, thumbnails, range reads, reports and exports. Test concurrent review conflicts, source duplicates with different payloads, worker crashes, connection-pool tenant reuse, hold/deletion races and restoration of revoked sessions. A schema validator passing is not proof that runtime isolation works.

For media, include truncated files, unsupported codecs, wrong declared MIME type, oversized payloads, timestamp drift and delayed final clips. For the companion, simulate disk pressure, camera reconnect storms, partial configuration, certificate expiry and failed signed updates. For optional existing outputs, use a software simulator before supervised testing of the documented existing interface and verify no repeated pulse after restart.

Run controlled UAT at each pharmacy using consenting staff, approved test merchandise and labelled records. For each enabled class, aim for at least forty staged positive actions and forty benign lookalikes across representative conditions, with a held-out session after thresholds are frozen. Include own bags, restocking, returned items, companion payment, crowds, children and accessibility aids without treating appearance as a trigger.

Metric	Proposed pilot gate	Interpretation
Critical release tests	All pass; no unresolved critical defect	Includes isolation and evidence; output tests apply when that option is enabled
Selected-view coverage	At least 98% of agreed trading-time camera minutes	Report each view; denominator excludes only agreed scheduled downtime
Staged event recall	At least 80% per enabled class/site	Report count and confidence interval; not real-world theft recall
Observable-event precision	At least 80% where sample is sufficient	Label observable action, not guilt; insufficient data remains inconclusive
Nonactionable alerts	Target at most 3/site/day; ceiling 5 pending agreed remediation	Tighter target than the research baseline; review all alert workload
Routine review effort	At most 10 minutes/site/trading day	Includes dismissals and corrections
Display latency	p95 at most 10 seconds from sufficient observable evidence to console	Measure source, companion, server and UI times; exclude/flag uncertain clocks
Incident preparation	Median under 3 minutes and at least 30% less than baseline	Include AI correction effort
Recovery	Demonstrated database RPO at most 15 minutes and core RTO at most 4 hours	Scoped restore drill, not a contractual life-safety guarantee

Treat these as acceptance targets to adopt at kickoff, not current measured performance. A quiet system that misses events does not pass. Audit permitted no-alert periods and independently discovered incidents to understand misses; recall cannot be calculated from alerts alone. Short controlled tests do not establish national efficacy or annual savings.

Begin with shadow review, then private notifications after critical checks and staff training. Record site-specific functional, detector and commercial outcomes separately: pass, limited release or fail. Disable unaccepted classes instead of hiding their errors. Run the eight-week live measurement period after commissioning, extending to twelve weeks if event counts or baseline comparability are inadequate.

18 Infrastructure CI and Deployment

For the two-site pilot, use an EU application VM for reverse proxy, static web, API and workers; a separate PostgreSQL VM on a private network; private EU object storage; managed identity; and independent encrypted backups. Docker Compose plus host supervision is an economical pilot topology. It is recoverable, not highly available. Container health checks need explicit restart, alerting and operator procedures.¹⁴

Use separate development, staging and production accounts/projects, credentials, buckets and databases. Development and CI use synthetic fixtures. Staging must not receive copied production video by default. Restrict administrative access through a controlled support path, keep database ports private and issue service credentials only for required resources.

The pipeline performs formatting/types, unit and integration tests, API/schema compatibility, isolation tests, browser workflows, secret/dependency scanning and container checks. Generate an SBOM, build immutable images and sign their digests. Cloud deployment credentials should be short-lived and bound to the repository/environment through OIDC where supported. Review branch/environment restrictions rather than trusting any workflow in the organisation.¹⁵

Promote a release through staging, a canary site and then remaining sites. Record application, schema, adapter, model and policy versions separately. Database migrations use expand/contract changes and maintain the previous supported API/companion version during rollout. Back up and test migration recovery; do not assume a destructive down migration can restore lost data.

Companion updates verify a signed manifest, digest, compatibility and disk space against pinned trust material; install alongside the previous version and roll back on failed health checks. Signing-key rotation is a documented overlap/revocation procedure. A failed canary stops the rollout. GitHub plan-dependent attestation features must be budgeted accurately; an independent signing/verification route is acceptable.¹⁶

Before scaling beyond the pilot, measure database/worker contention, video throughput and support demand. Add replicas, managed database availability or additional worker hosts when the measured service objective requires them. Kubernetes is not an initial prerequisite. More sites do not automatically require more architectural components, but a single application VM should not be sold as highly available.

19 Capacity Costs and Recovery

Use the same transparent workload assumptions as the business case: 20 candidate events per trading day, 26 trading days monthly, and a final thirty-second clip at 2 Mbps. This is approximately 7.5 MB per event and 3.9 GB of incoming media per site monthly before derivatives, held cases, exports and backups. At 100 sites it is approximately 390 GB monthly and 52,000 events. These are decimal units and planning volumes, not detector measurements.

One heartbeat per minute from 100 companions averages 1.67 requests per second. Bursty callbacks, reconnect backlogs, many concurrent video reads and transcodes govern peak sizing more than that average. Test at least ten times the planned metadata peak plus realistic video/export concurrency. Reserve worker capacity so an export burst cannot delay private alerts.

The confirmed offer is EUR 60 monthly for one pharmacy branch. A subscription belongs to organisation_id and site_id, with one included branch. Additional branches need their own agreed subscriptions; registering a site

¹⁴ Docker. [Compose in production](#).

¹⁵ GitHub. [OpenID Connect for deployment security](#).

¹⁶ GitHub. [Artifact attestations](#); Sigstore. [Cosign verification](#).

alone must never charge the customer or activate a paid entitlement. Tax treatment and payment fees are unresolved, so the amounts below are before those deductions and are not net profit.

There is no new-hardware purchase, installation, depreciation or replacement-reserve line in this baseline. Use the pharmacy's existing laptop and existing camera/recorder interfaces. Earlier equipment and hardware-installation cost assumptions are withdrawn. Existing laptop electricity, staff availability and software setup effort are measured operating inputs rather than invented equipment charges.

For comparison, retain shared platform allowances of EUR 80/180/400 at 2/25/100 paid branches, plus EUR 5 product AI and EUR 5 storage/notifications per branch monthly. Separately show owner support time valued at the prior EUR 15 per branch; it is not a hired salary or cash invoice. These are assumptions requiring real invoices and workload measurements. Detector licences, software signing, Codex/development usage, tax and payment fees remain additional unknowns.

Paid branch subscriptions	Revenue per month	Hosting and product usage allowance	Remaining after owner support valuation
2	EUR 120	EUR 100	EUR -10
25	EUR 1500	EUR 430	EUR 695
100	EUR 6000	EUR 1400	EUR 3100

Before the owner-time valuation, this leaves EUR 10, EUR 42.80 and EUR 46 per branch at 2, 25 and 100 subscriptions respectively. After that valuation, the respective headroom is negative EUR 5, EUR 27.80 and EUR 31. These are ceilings before detector fees, tax, development-model spend, distribution signing and other overhead, not profit forecasts. Removing hardware purchase materially improves the model, but the available laptop still has to meet the actual software workload.

Start by implementing the branch subscription record with the exact price of 6000 EUR cents monthly and manual billing status. No live payment or invoice-sending automation is part of this baseline. Do not let unverified tax or software terms become a published checkout. The smallest cost-controlled release is the incident/evidence workflow with existing CCTV access where permitted, event-limited uploads and optional factual drafts. Integrated detection is enabled only after its true cost and quality fit the approved offer. Document permitted software installation, camera limits, existing laptop availability and support coverage. If the existing laptop or camera interface is unsuitable, retain the supported manual workflow or reduce scope; do not buy replacement equipment or silently add charges.

Treat the EUR 5 model allowance as a per-subscription ceiling for its single branch. Reserve costs against organisation/site/month. A newly registered branch has no billable entitlement or model allocation until its separate subscription or explicit trial is authorised. Continuous cloud video analysis is outside that allowance; small report jobs must remain useful when AI is off. Choose image use only if its measured value and data scope justify the extra cost.

Implementation is delivered by Codex and agents, so the earlier hired-team day-rate budget is withdrawn. Track actual development-model usage or subscription capacity, cloud bills, software-distribution costs and laptop onboarding effort and Jawahir's time. The backlog uses relative complexity weights for prioritisation only; these are not person-days, token estimates or delivery guarantees. Optional sounder and later stock work retain separate acceptance gates.

The restore plan includes database base backups and WAL archiving, object versions/backups as appropriate, deployment configuration, device inventory and deletion/revocation journals. Database PITR does not restore media bytes by itself. Monitor archive failure and verify recoverability; a backup job reporting success is insufficient.¹⁷

Restore into an isolated environment, reapply the latest deletion and revocation records, verify schema/application compatibility and reconcile media manifests and pending work. Revoke uncertain sessions and device leases. Open access only after tenant isolation, representative evidence reads and critical workflow checks pass. The four-hour RTO targets core metadata, authentication and representative available media at pilot size; a full large-media restore has a separately measured objective.

20 Operating Runbooks and Support

Provide a daily operator view of camera/detector coverage, companion age, queued jobs, storage/backup status, AI usage and unresolved security events. Review failed exports/deletions and temporary access grants. Weekly checks include patch status, restore sampling, model drift, supplier changes and support time per site. Incident narratives and faces do not belong in monitoring dashboards.

Runbook	First response	Recovery evidence
Camera or companion outage	Confirm scope, show unavailable coverage, contact the pharmacy or its existing IT contact through the agreed channel	Requalified feed, clock and detector health; missing interval recorded
Alert flood	Suspend affected class/site routing without erasing cases; preserve version and sample	Root cause and held-out retest before re-enabling
Suspected account compromise	Revoke sessions/grants, block exports/actions and assess affected resources	Credential recovery and scoped access review
Data incident	Restrict affected access, preserve necessary logs, notify controller contact	Documented containment and notification assessment
Export or deletion failure	Restrict expired access, inspect job/object state and correct within current authority	Manifest or deletion verification plus audit
Database restore	Isolate, restore, reapply journals, reconcile and test	Recorded RPO/RTO and tenant/media checks
Unknown sounder state	Stop retries, inspect local feedback and use established site procedure	Authorised verification of the existing interface
Customer termination	Authorised export, credential revocation, device detach and deletion schedule	Access-denial test and deletion/backup-expiry record

Agree actual support hours and escalation contacts before the live pilot. Classify possible data exposure, unsafe output behaviour or total agreed-site service loss as P1; material partial outage as P2; ordinary requests as P3.

¹⁷ PostgreSQL. [Continuous archiving and point-in-time recovery](#).

Response targets must match Jawahir and the pharmacy's actual availability. Do not sell a thirty-minute or 24-hour response promise on the assumption that agents are continuously running.

Jawahir must name a human operational contact and site alternate before live activation. Codex and agents do not provide an unattended on-call service. Record who can suspend a detector, revoke a device, approve a support grant, restore data and contact the pharmacy. The software does not become a monitored alarm service through the presence of a notification feature. Any connection to an existing security system must respect the current supplier contract and applicable licensed scope; it does not authorise new equipment or wiring work. ¹⁸

21 Backlog Traceability and Definition of Done

Epic and period	Deliverable and release	Complexity weight	Dependencies
E01 W1	Discovery and integration spike (MVP)	10	None
E02 W1	Repository infrastructure and CI (MVP)	8	None
E03 W2	Identity tenancy and role enforcement (MVP)	10	E02
E04 W2	Site device and policy management (MVP)	10	E01, E03
E05 W3	Incident workflow and console (MVP)	14	E03
E06 W3-W4	Evidence ingest playback and exports (MVP)	14	E03, E04
E07 W4	Laptop companion and detector adapter (MVP)	14	E01, E04, E06
E08 W4-W5	Notifications duty routing and assistance (MVP)	8	E05
E09 W5	Bounded incident drafting (MVP)	6	E05, E06
E10 W5-W6	Retention audit rights and offboarding (MVP)	10	E03, E06
E11 W5-W6	Operational metrics and reporting (MVP)	6	E05, E07
E12 W6	Recovery performance and release hardening (MVP)	10	E06, E07, E08, E09, E10, E11
E13 After core gate	Optional commissioned sounder (OPTION)	8	E04, E05, E08, E12
E14 After pilot gate	Read-only stock and procedure extensions (P2)	20	E05, E10, E11, E12

The core epics total 120 relative complexity units. These weights compare scope only and do not translate to human days or an AI completion date. Parallel work must respect dependencies: the web console can use the simulator while the adapter is procured, but accepted live alerts require both. Some requirements span multiple

¹⁸ Private Security Authority. [Contractor licensing introduction](#).

epics; shared traceability does not duplicate their scope allocation. Split each epic into reviewable tickets with the relevant requirement IDs, data/API change, test evidence and rollout impact.

A ticket is done when the behaviour works in the intended role/site scope, normal and negative tests pass, schema/API changes are documented, logs contain no sensitive leakage, metrics identify failure, and operational instructions are updated where necessary. A screen mock-up, successful API response or passing schema validator alone is insufficient.

A release candidate is done when migrations and rollback have been rehearsed, evidence/retention/rights workflows are complete, all critical isolation tests and all enabled optional-output tests pass, dependency/model licences are recorded, support and commissioning records are ready, and the release matrix accurately names supported devices, suppliers and classes. The site release additionally needs trained reviewers, qualified views and a scoped pilot agreement.

Kickoff work is concrete: establish the supplied repository and local environments; assign the lead and bounded agent tasks and name pharmacy contacts; complete the two site inventories; obtain supplier event/media documentation and total pricing; freeze the normalised contract; implement the simulator; and start identity, tenancy and incident work. The first demonstration should use synthetic data and show one complete alert-to-closed-incident flow, including a benign dismissal and a denied cross-tenant request.

References

Official sources support platform capabilities and deployment obligations. Product defaults, schedules, thresholds and effort are engineering proposals. Sources were checked on 13 September 2026; pin current versions and commercial terms at implementation.

1. Veession. [Partner programme](#); Vision247. [Advertised deployment model](#); Solink. [API authentication](#). Commercial integration rights remain to be obtained.
2. AWS. [Cognito security best practices](#), [regional endpoints](#) and [pricing](#). Identity, email, SMS and machine-identity charges must be evaluated separately.
3. PostgreSQL. [Row Security Policies](#), including owner/privileged-role behaviour and foreign-key considerations.
4. OWASP. [API1 Broken Object Level Authorization](#), API Security Top 10 2023.
5. React. [Build a React App from Scratch](#); FastAPI. [Containers and Docker](#).
6. ONVIF. [Profile T](#); FFmpeg. [RTSP protocol support](#). Stream access is not theft-detection validation.
7. PyInstaller. [Operating mode and platform-specific bundles](#); Apple. [Developer ID signing and notarisation](#). Packaging and distribution accounts require separate setup.
8. Microsoft. [System power management events](#). Suspend can interrupt processing and may occur without normal notification.
9. OpenAI. [GPT-4.1 mini](#), [image-input guide](#) and [API data controls](#).
10. RWA. [Pharmacy partners and integrations](#). Listed integrations do not establish AisleSignals access rights or fees.
11. Irish DPC. [CCTV guidance](#) and [DPIAs](#); Irish Data Protection Act 2018. [Section 55](#).
12. European Union. [GDPR](#), particularly data-subject rights, processor duties and personal-data breach provisions.
13. PostgreSQL. [SELECT and SKIP LOCKED](#); FastAPI. [Background Tasks](#).
14. Docker. [Compose in production](#).
15. GitHub. [OpenID Connect for deployment security](#).
16. GitHub. [Artifact attestations](#); Sigstore. [Cosign verification](#).
17. PostgreSQL. [Continuous archiving and point-in-time recovery](#).
18. Private Security Authority. [Contractor licensing introduction](#).